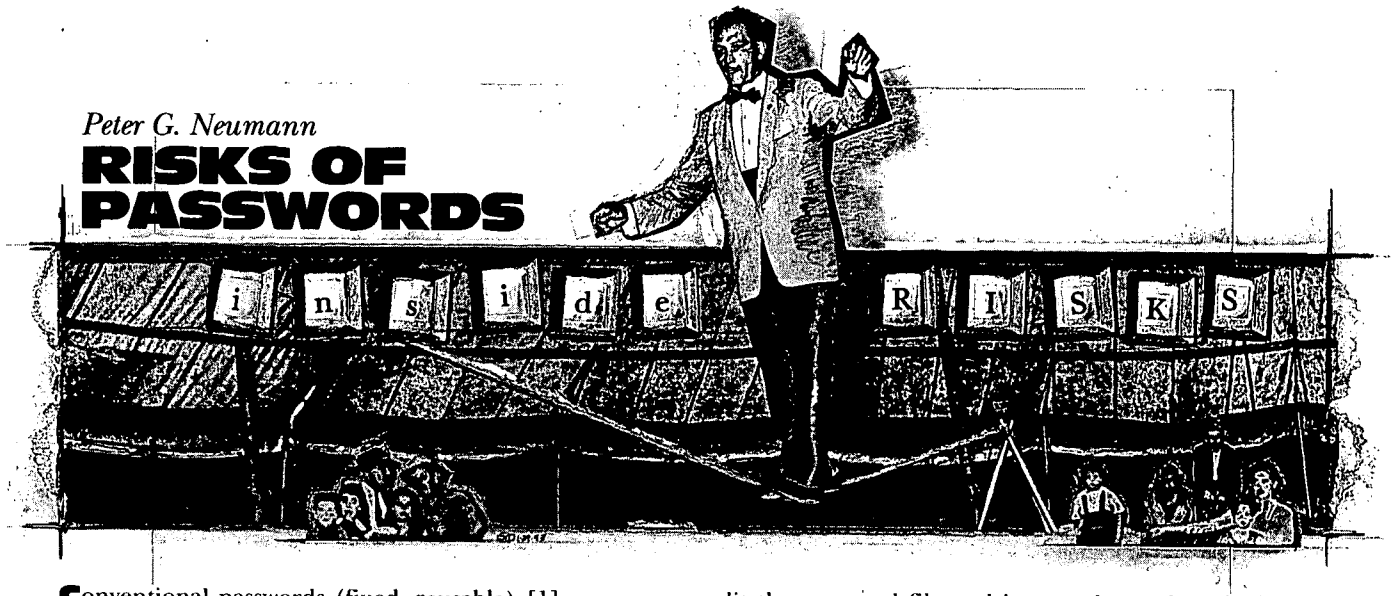
Peter G. Neumann

RISKS OF PASSWORDS



Conventional passwords (fixed, reusable) [1] may seem convenient, but they are also dangerous. Modes of attacks include the following:

• **Exhaustive attacks.** Attempting password attacks by random trial and error was at one time occasionally successful, but is now unlikely to succeed because of limits on the number of incorrect tries and auditing of failed attempts.

• **Educated guessing of passwords.** At least until recently, users frequently chose as passwords dictionary words, proper names, or other character strings having a logical association with the individual (such as initials, spouse's name, dog's name, or social security number). System passwords sometimes remain unchanged from the original defaults. Maintenance passwords are often common across different systems. Such passwords have been guessed surprisingly often.

• **Deriving passwords.** If words or names are chosen as passwords, then—even if the passwords are stored in an encrypted form—they can be discovered by preencryptive dictionary attacks [2], assuming the encrypted password file can be read. Such attacks are particularly insidious, because they can be carried out surreptitiously on systems other than the ones being attacked. Algorithmically generated passwords may also be prone to attack. For example, knowing one password in a pseudorandom sequence can be used to determine the subsequent ones.

• **Capturing unencrypted passwords.** Passwords exist in an unencrypted form as they are being typed, stored in memory, or in transit across a local or global network. They can be captured by exploiting system security flaws (or features) and by network snooping. Trojan horsing with network software (such as *ftp* and *telnet*) on various host systems has recently enabled the capture of passwords for accounts on other systems, and the newly captured passwords have then been used to implant Trojan horses on those other systems. Someone's ability to capture passwords that you may use to access other systems from your own host system may in turn compromise users on those other systems.

• **Creating bogus passwords and trapdoors.** Trojan horses may subvert user authentication—for example, by inserting a trapdoor into a security-critical program. The classical example is the C-compiler Trojan horse described by Ken Thompson [3] that could implant a trapdoor in the login routine. Also, if a password file is not properly protected against writing, a clever perpetrator may be able to edit the password file and insert a bogus but viable self-chosen user identifier and password (encrypted as needed), or to install a variant password file.

• **Bypassing authentication.** Users and administrators may inadvertently permit access to other more sensitive systems without further authentication, as can happen with the Unix *.rhost* mechanism. In certain cases, trapdoors exist that permit initial system access without any user authentication. In at least one case, an implementation flaw led to the accidental existence of universal passwords [4], similar to skeleton keys that open a wide range of locks.

• **Nonatomic password checking.** Some years ago, there were cases of applications in which the password checking could be subverted by a judiciously timed interrupt during the authentication process. This problem appears to have disappeared in operating systems, but is still found in some applications.

Common advice to improve password management includes monitoring failed login attempts, changing passwords regularly, and avoiding easily guessed passwords. Such advice can reduce the likelihood of the first three attack modes. The use of servers can reduce the likelihood of some of the other modes (at least with respect to external client attacks, but not necessarily with respect to insider attacks); however, supposedly trusted servers are often not sufficiently trustworthy.

These modes illustrate the conclusion that reusable passwords are inherently risky, because they are susceptible to attack. If any of these modes are possible in any one of your systems or on any systems from which your systems can be used (by network or dial-up line), you and many others are vulnerable. The next "Inside RISKS" considers nonreusable one-time authenticators and smart-card technology, which can reduce the vulnerabilities considerably. ◻

References

1. Denning, P.J. Passwords. *Am. Sci. 80*, 2 (March/Apr. 1992), 117–120.
2. Morris, R. and Thompson, K.L. Password security: A case history. *Commun. ACM 22*, 11 (Nov. 1979), 594–597.
3. Thompson, K.L. Reflections on trusting trust. *Commun. ACM. 27*, 8 (Aug. 1984), 761–763.
4. Young, W.D. and McHugh, J. Coding for a believable specification to implementation mapping. *In Proceedings of the 1987 Symposium on Security and Privacy*, pp. 140–148.

***Peter G. Neumann** moderates the ACM RISKS Forum. Send email to risks-request@csl.sri.com for an on-line subscription.*

Copyright of Communications of the ACM is the property of Association for Computing Machinery and its content may not be copied or emailed to multiple sites or posted to a listserv without the copyright holder's express written permission. However, users may print, download, or email articles for individual use.